

## UNIT 4

### 3.4

## CASE STUDY: Incident Post-Mortem Family-Owned Construction Company - Online Banking Fraud

A small family-owned construction company regularly used online banking. Employees logged in with both a company and user-specific ID and password. Two challenge questions had to be answered for transactions over £1000.

One day, the owner was notified that a transfer of £10 000 was initiated by an unknown source. They contacted the bank and identified that in just one week, cyber criminals had made six transfers from the company bank accounts, totalling £550 000. An investigation found that one of their employees had opened an email from what they thought was a materials supplier but was instead a malicious email that contained malware from an imposter account.

The attackers were able to install malware onto the company's computers, using a keylogger to capture the banking credentials. They used this info to access banking and other financial services online, using valid account numbers and passwords.

The bank was able to retrieve only £200 000 of the stolen money in the first weeks, leaving a loss of £350 000. Not having a cyber security plan in place delayed the company response to the fraud. The company shut down their bank account and pursued legal action to recover its losses.

Write up a very brief incident post-mortem for this incident and reflect on the incident post-mortem that you drew up and make recommendations based on the findings.

### Incident Post-Mortem:

**Report ID:** PM-2025-001

**Incident Date:** date of discovery

**Participants:** Owner, Finance Manager, IT Support, Bank Security Team

#### 1. Executive Summary

Over one week, cyber criminals stole £550,000 from the company's bank accounts by gaining access through malware installed on employee computers. The attack began with a phishing email disguised as a materials supplier. Only £200,000 was recovered, leaving a net loss of £350,000. The company did not have a cyber security plan, which delayed the response.

#### 2. Timeline of Events

- Employee opened a phishing email from an imposter account
- Malware with keylogger installed on company computers
- Banking credentials were captured and used to make six unauthorised transfers
- Owner alerted the bank after noticing a £10,000 transaction
- Bank blocked further transfers and recovered £200,000
- Company closed bank accounts and pursued legal action

### 3. Root Cause Analysis

- Employee clicked a phishing email
- No endpoint protection or malware detection in place
- No cyber security incident response plan existed to guide the team
- Lack of multi-factor authentication or transaction monitoring allowed fraud to continue

### 4. Impact

- Financial: £350,000 unrecovered loss
- Operational: Disruption to banking and cash flow
- Reputational: Loss of confidence in financial management

### 5. Lessons Learned

- Employees need **regular cyber security training** on phishing and email threats
- Company should implement **multi-factor authentication** for online banking
- Cyber security policies and response plans are essential, even for small businesses
- Regular monitoring of financial accounts could have detected the fraud earlier

### 6. Recommendations

1. Develop and maintain a **cyber security incident response plan**
2. Introduce **anti-malware software** on all company devices
3. Implement **multi-factor authentication** for all banking transactions
4. Conduct **phishing awareness training** for all employees
5. Establish a **banking monitoring procedure** for unusual transactions
6. Schedule periodic **tests of incident response procedures**

## Reflection on Incident Post-Mortem

The incident post-mortem highlights several key issues that contributed to the financial loss and delayed response:

1. **Human Error:** The initial breach occurred because an employee opened a phishing email. This demonstrates the importance of employee awareness and training in cyber security.
2. **Lack of Security Measures:** The company did not have malware protection, endpoint monitoring, or multi-factor authentication for banking transactions. These gaps allowed attackers to install keyloggers and execute multiple fraudulent transfers.
3. **No Incident Response Plan:** Without a formal cyber security incident response plan, the company's reaction was delayed and uncoordinated, which limited the speed of recovery and increased the financial impact.
4. **Insufficient Monitoring:** Daily or real-time monitoring of banking transactions could have detected irregular activity earlier, potentially limiting the number and amount of fraudulent transfers.
5. **Financial and Operational Impact:** The company suffered a significant financial loss (£350,000) and disruption to operations, and faced reputational risks.

## Recommendations Based on Findings

To prevent similar incidents in the future and improve preparedness:

### **1. Develop a Cyber Security Incident Response Plan (IRP):**

- Assign clear roles and responsibilities
- Define procedures for detection, containment, eradication, and recovery
- Include a communication plan for staff, the bank, and legal advisors

### **2. Employee Cyber Awareness Training:**

- Conduct regular phishing simulations and awareness programs
- Ensure employees understand the risks and how to report suspicious emails

### **3. Implement Multi-Factor Authentication (MFA):**

- Apply MFA to all online banking and critical financial systems
- Ensure that even if credentials are stolen, attackers cannot easily access accounts

### **4. Install and Maintain Security Software:**

- Anti-malware and endpoint protection on all company devices
- Regular updates to prevent exploitation of known vulnerabilities

### **5. Transaction Monitoring and Alerts:**

- Establish daily checks or automated alerts for unusual transfers
- Set thresholds for approvals and notifications for transactions over a defined amount

### **6. Regular Testing of IRP and Recovery Procedures:**

- Conduct tabletop exercises and simulations to ensure staff know how to respond
- Review and update procedures periodically based on lessons learned

### **7. Banking Risk Mitigation:**

- Limit employee access to banking credentials to only those necessary
- Consider using separate accounts for operational and high-value transactions

This reflection shows that the losses and delays could have been reduced through a combination of staff training, security tools, monitoring, and having a formal, tested incident response plan. The recommendations focus on people, processes, and technology to strengthen the company's overall cyber resilience.